



# 온큐베이트 리딩스튜디오

## 홈페이지·서버·데이터베이스 연동 개발 가이드

자율활동 회원과 실시간 수업 사용자를 안전하게 분리하고, 승인된 강사만 양방향 수업 기능을 사용할 수 있도록 하기 위한 개발자 전달 문서

### 현재 결론

모두 완료된 상태가 아닙니다. 자료 화면, 공통 활동 추적 기반, 새 입장 화면은 적용되었습니다. Firebase Authentication, 구매 권한 확인, 5자리 수업방, Firestore 구조와 Security Rules는 아직 연결해야 합니다.

| 문서 정보  | 내용                                                                                                                |
|--------|-------------------------------------------------------------------------------------------------------------------|
| 작성일    | 2026년 7월 25일                                                                                                      |
| 대상     | 홈페이지·앱·Firebase 개발자                                                                                               |
| 현재 서비스 | <a href="https://sori-reading-check.hi3957348.chatgpt.site">https://sori-reading-check.hi3957348.chatgpt.site</a> |
| 신규 저장소 | <a href="https://github.com/oncuvate/oncuvate-lessons">https://github.com/oncuvate/oncuvate-lessons</a>           |
| 목표 환경  | 앱/웹 자율활동 + 클래스인 실시간 양방향 수업                                                                                        |

### 문서 사용법

- 1~3장은 현재 상태와 서비스 권한 구조를 확인합니다.
- 4~8장은 개발자가 구현할 서버·데이터베이스·보안 작업입니다.
- 9장은 테스트 합격 기준이며, 모두 통과한 뒤 실제 학생을 등록합니다.

## 1. 현재 완료 상태

완료 여부는 화면이 보이는지뿐 아니라 서버 권한과 데이터 보호까지 포함하여 판단했습니다.

| 상태  | 항목              | 현재 내용                                         |
|-----|-----------------|-----------------------------------------------|
| 완료  | 리딩스튜디오 자료 화면    | 10개 그림책에 최신 공통 디자인과 읽기 활동 적용                  |
| 완료  | 새 입장 화면         | 자율활동 / 실시간 수업 참여 / 강사 로그인으로 분리                |
| 완료  | 고정 강사 코드 화면 제거  | 강사 화면에서 공용 숫자 코드를 입력하는 UI 제거                  |
| 완료  | 활동 추적 기반        | activityId, 자동 저장 상태, 오프라인 임시 보관, 요약 지표 기반 존재 |
| 부분  | 5자리 방 코드 화면     | 입력 UI는 적용됐으나 실제 활성화 방 조회·검증 서버는 미완료           |
| 부분  | 계정 로그인 연결 지점    | OncuvateAuth 연결 규격은 준비됐으나 Firebase Auth 미연결   |
| 미완료 | 회원 구매·구독 확인     | entitlements 저장과 결제 검증 서버 필요                  |
| 미완료 | 승인 강사 권한 확인     | Firebase UID와 coach 권한 확인 필요                  |
| 미완료 | Cloud Firestore | 컬렉션, 인덱스, 서버시간, 보고서 저장 구조 필요                  |
| 미완료 | Security Rules  | 기본 거부 및 역할별 읽기·쓰기 규칙 필요                       |

### 실제 학생 사용 전 조건

현재 버전은 화면 구조를 확인하기 위한 단계입니다. 아래 서버·인증·보안 작업과 권한 테스트를 완료하기 전에는 실제 학생 이름이나 학습기록을 저장하지 않습니다.

### 현재 코드에서 교체해야 하는 부분

- 학생 인증 API는 아직 환경변수의 고정 학생 코드 방식입니다.
- 강사 인증 API는 아직 환경변수의 고정 강사 코드 방식입니다.
- 활동 저장 API는 Realtime Database REST와 관리자 비밀번호 방식입니다.
- 학생 내부 ID가 이름·코드 등 변경 가능한 값의 조합에 의존합니다.

## 2. 서비스 운영 모드와 권한

| 구분    | 자율활동             | 실시간 수업             |
|-------|------------------|--------------------|
| 대상    | 유료 구독자 또는 자료 구매자 | 승인된 강사와 참여 학생      |
| 표시 명칭 | 자율활동             | 실시간 수업 참여 / 강사 로그인 |
| 회원 인증 | 구매자 계정 로그인       | 강사만 정식 로그인         |
| 학생 입장 | 계정의 아동 프로필 선택    | 이름 + 활성 5자리 방 코드   |
| 강사 연동 | 사용 불가            | 승인 강사만 사용 가능       |
| 자료 이동 | 사용자가 자유롭게 이동     | 강사가 페이지·활동 진행 제어   |
| 기록 소유 | 회원 계정의 아동 프로필    | 해당 강사의 수업 세션       |

### 권장 입장 흐름

| 단계 | 자율활동             | 실시간 수업               |
|----|------------------|----------------------|
| 1  | 회원 계정으로 로그인      | 강사가 계정으로 로그인         |
| 2  | 서버가 구매·구독 이용권 확인 | 서버가 coach 권한 확인      |
| 3  | 아동 프로필 선택        | 서버가 5자리 방 생성         |
| 4  | 자율활동 세션 생성       | 학생이 이름과 방 코드 입력      |
| 5  | 강사 기능 없이 자료 이용   | 서버가 임시 학생 토큰 발급      |
| 6  | 개인 진도 자동 저장      | 강사 제어와 학생 결과를 실시간 연결 |

#### 중요한 보안 원칙

화면에서 강사 메뉴를 숨기는 것만으로는 충분하지 않습니다. 방 생성, 학생 제어, 결과 조회 요청마다 서버가 로그인 UID와 유효한 coach 권한을 다시 확인해야 합니다.

### 3. 홈페이지·앱 개발자가 연결할 화면 기능

공통 자료는 한 벌만 유지하고 실행 모드와 권한만 분리합니다.

| 우선순위 | 작업                  | 구현 기준                                                  |
|------|---------------------|--------------------------------------------------------|
| P0   | Firebase 로그인 SDK 연결 | window.OncuvateAuth.signIn({kind}) 규격에 회원·강사 로그인 결과 연결 |
| P0   | 자율활동 권한 확인          | 로그인 후 entitlement가 active인 콘텐츠만 열기                     |
| P0   | 강사 권한 확인            | role=coach이며 이용권이 유효한 계정만 방 생성                         |
| P0   | 학생 수업 입장            | 5자리 코드와 이름 전송, 활성 방 확인 후 임시 인증                         |
| P1   | 아동 프로필 선택           | 학생 이름 대신 변경 불가능한 studentId를 기록에 사용                     |
| P1   | 자동 저장 상태            | 저장됨 / 저장 중 / 연결 후 저장 예정 표시 유지                          |
| P1   | 세션 종료 처리            | 강사 종료, 만료, 중복 로그인에 대한 안내와 정리                           |
| P2   | 접근성                 | 키보드 탐색, 초점 표시, aria-live 오류 안내, 40px 이상 터치 영역          |

#### 프론트엔드 인증 연결 규격

```
window.OncuvateAuth.signIn({ kind: 'member' | 'coach', lessonTitle }) → { authenticated, uid, role, entitled, studentName?, roomCode? }
```

- member 결과에는 authenticated=true와 entitled=true가 모두 필요합니다.
- coach 결과에는 authenticated=true, role=coach, 서버가 발급한 5자리 roomCode가 필요합니다.
- 브라우저가 전달한 role 또는 entitled 값을 서버가 그대로 신뢰하면 안 됩니다.

### 4. 필요한 서버 API

| API                                    | 인증                 | 주요 역할                     |
|----------------------------------------|--------------------|---------------------------|
| POST /api/auth/session                 | 회원·강사 ID 토큰        | 토큰 검증 후 사용자 역할·상태 반환      |
| GET /api/entitlements/:lessonId        | 회원                 | 구매·구독 콘텐츠 이용 가능 여부 확인     |
| POST /api/live-rooms                   | coach              | 수업 ID를 받아 활성 5자리 방 생성     |
| POST /api/live-rooms/join              | 없음→임시 토큰           | 방 코드·이름 확인 후 제한된 학생 토큰 발급 |
| PATCH /api/live-rooms/:id/state        | 방 소유 coach         | 현재 페이지·활동·잠금 상태 변경        |
| POST /api/activity-events              | 학생/회원              | 필드 검증 후 활동 사건 추가          |
| POST /api/lesson-sessions/:id/complete | 회원/coach           | 수업 종료, 요약값 계산 요청          |
| GET /api/reports/:studentId            | parent/coach/admin | 관계·담당 여부 확인 후 보고서 조회      |

### 공통 서버 검증

모든 쓰기 요청에서 ID 토큰, 역할, 이용권, lessonId, lessonVersion, sessionId, activityId, 요청 필드 형식과 문서 소유 관계를 확인합니다. 관리자 키는 브라우저로 보내지 않습니다.

## 5. Cloud Firestore 데이터 구조

한국 사용자가 중심이면 새 Firestore 데이터베이스 위치로 asia-northeast3(서울)을 권장합니다. 위치는 생성 후 변경할 수 없습니다.

| 컬렉션            | 문서 ID             | 필수 내용                                                                                  |
|----------------|-------------------|----------------------------------------------------------------------------------------|
| users          | Firebase Auth UID | role, displayName, status, createdAt, updatedAt                                        |
| students       | 자동 생성 고정 ID       | displayName, status, guardianIds, createdAt, updatedAt                                 |
| studentCodes   | 표시코드 또는 자동 ID     | studentId, code, status, expiresAt                                                     |
| entitlements   | 자동 ID             | userId, lessonIds/상품, type, status, startsAt, endsAt                                   |
| lessons        | READING-001 등     | title, version, status, availableModes                                                 |
| enrollments    | 자동 ID             | studentId, coachId, status, startsAt, endsAt                                           |
| liveRooms      | 서버 내부 ID          | roomCode, coachId, lessonId, state, expiresAt                                          |
| lessonSessions | 자동 ID             | studentId, lessonId, lessonVersion, mode, status, startedAt, completedAt               |
| activityEvents | 고유 eventId        | studentId, sessionId, activityId, eventType, attemptNumber, isCorrect, durationSeconds |
| reports        | 자동 ID             | studentId, period, metrics, generatedAt, generatedBy                                   |

### 모든 문서의 공통 필드

| 필드        | 규칙                                                 |
|-----------|----------------------------------------------------|
| createdAt | Firestore 서버 저장시간                                  |
| updatedAt | 마지막 변경 서버시간                                        |
| createdBy | Firebase UID 또는 검증된 sessionId                      |
| status    | active / completed / cancelled / expired 등 허용값만 사용 |

### 학생 ID 원칙

studentId는 Firestore 자동 ID처럼 변경 불가능한 값이어야 합니다. 학생 이름, 표시코드, 방 코드가 바뀌어도 studentId는 유지되어야 기존 학습기록이 끊기지 않습니다.

## 6. Authentication과 Security Rules

역할은 student, parent, coach, admin 네 가지로 운영합니다.

| 주체              | 허용                           | 반드시 거부                      |
|-----------------|------------------------------|-----------------------------|
| student         | 자신의 활성 세션에 activityEvents 생성 | 타 학생 조회, 기존 사건 수정·삭제, 강사 제어 |
| parent          | 연결된 자녀 reports 조회            | 다른 아동 기록 조회, 원본 활동 수정       |
| coach           | 담당 학생 기록 조회, 자신이 만든 방 제어     | 미담당 학생 조회, 타 강사 방 제어        |
| admin           | 전체 관리                        | 클라이언트에서 관리자 권한 자체 발급        |
| unauthenticated | 활성 방 참가 요청의 최소 입력            | 개인정보·보고서·강사 기능 접근           |

### activityEvents 규칙

- 학생 클라이언트는 create만 허용하고 update와 delete는 항상 거부합니다.
- request.auth.uid 또는 토큰의 sessionId가 요청 문서의 학생 세션과 일치해야 합니다.
- lessonId, lessonVersion, activityId, eventType 등 허용 필드를 명시적으로 검사합니다.
- 오프라인 재전송 중복을 막기 위해 클라이언트가 만든 고유 eventId를 문서 ID로 사용합니다.
- 관리자 SDK를 사용하는 서버는 Security Rules를 우회하므로 서버 코드에서 동일한 권한 검사를 수행합니다.

### 방 코드 보안

- 5자리 코드는 학생의 방 참가용이며 강사 인증 수단이 아닙니다.
- 방은 만료시간, 소유 coachId, 최대 참가 수, 상태(active/closed)를 가집니다.
- 코드 입력 실패 횟수 제한과 IP-기기 기준 요청 속도 제한을 적용합니다.
- 강사 계정당 동시 활성 방 수를 제한합니다.

## 7. 저장소에 추가할 파일

| 파일                                | 현재       | 용도                                   |
|-----------------------------------|----------|--------------------------------------|
| docs/lesson-standard.md           | 없음       | 수업 ID, 버전, activityId, 추적 규칙         |
| templates/lesson-template.html    | 없음       | 신규 수업 제작 기본 템플릿                      |
| public/common/activity-tracker.js | 있음·개편 필요 | Firebase 인증 토큰과 Firestore 저장 방식으로 변경 |
| firestore.rules                   | 없음       | 데이터 접근 권한                            |
| firestore.indexes.json            | 없음       | 보고서·수업 검색 인덱스                        |
| firebase.json                     | 없음       | Rules, Emulator, 배포 설정               |
| .gitignore                        | 있음·보강 필요 | 비밀파일 제외 패턴 추가                        |
| README.md                         | 있음·개편 필요 | 설치, 환경변수, 테스트, 배포 안내                 |
| tests/firestore.rules.test.*      | 없음       | 권한 자동 테스트                            |

## GitHub 제외 항목

```
.env .env.local service-account*.json firebase-admin*.json
```

## 8. 권장 개발 순서

| 단계 | 개발 작업                | 완료 조건                                               |
|----|----------------------|-----------------------------------------------------|
| 1  | 테스트 Firebase 프로젝트 생성 | Firestore 서울 리전, Auth, 개발용 데이터만 사용                  |
| 2  | 스키마·Rules·인덱스 작성     | 전체 거부 기본값과 역할별 최소 권한                                |
| 3  | 회원·강사 로그인 연결         | UID와 서버 권한으로 member/coach 구분                        |
| 4  | entitlements 구현      | 구매·구독 취소·만료까지 서버에서 판정                               |
| 5  | 5자리 수업방 구현           | 활성·만료·소유권·중복 제한 작동                                  |
| 6  | 학생 임시 인증 구현          | 방 참가 범위에 한정된 토큰과 sessionId 발급                       |
| 7  | 활동 저장 전환             | Realtime Database REST 제거, Firestore append-only 기록 |
| 8  | 보고서 집계               | 완료 수, 정답 수, 시도 수, 힌트 수, 총 활동시간 계산                   |
| 9  | Emulator 자동 테스트      | 권한 테스트 전체 통과                                        |
| 10 | 가상 사용자 통합 테스트        | 학생2·학부모1·강사1·관리자1로 교차 접근 확인                         |
| 11 | 운영 프로젝트 분리           | 실제 학생 정보는 운영 환경에서만 사용                               |
| 12 | App Check 단계 적용      | 모니터링 후 강제 적용, 내장 브라우저 정상 확인                         |

## 예산과 모니터링

- 프로젝트 단위 예산 알림을 설정하되 예산 알림이 자동 사용 중단 기능은 아니라는 점을 운영자가 인지합니다.
- 인증 실패, 권한 거부, 방 생성, 방 참가, 보고서 조회를 감사 로그로 남깁니다.
- 실제 이름은 필요한 컬렉션에만 두고 activityEvents에는 studentId를 사용합니다.

## 9. 테스트 합격 기준

Firebase Emulator Suite와 @firebase/rules-unit-testing으로 아래 항목을 자동화합니다.

| 번호  | 시험                         | 기대 결과                |
|-----|----------------------------|----------------------|
| T01 | 학생 A가 자신의 활성 세션에 사건 생성     | 허용                   |
| T02 | 학생 A가 학생 B의 사건 생성·조회       | 거부                   |
| T03 | 학생이 기존 activityEvent 수정·삭제 | 거부                   |
| T04 | 학부모가 연결된 자녀 보고서 조회         | 허용                   |
| T05 | 학부모가 다른 아동 보고서 조회          | 거부                   |
| T06 | 강사가 담당 학생 기록 조회            | 허용                   |
| T07 | 강사가 미담당 학생 기록 조회           | 거부                   |
| T08 | 자율활동 회원이 liveRoom 생성       | 거부                   |
| T09 | 승인 coach가 liveRoom 생성      | 허용, 5자리 코드 반환        |
| T10 | 일반 사용자가 강사 화면 API 호출       | 거부                   |
| T11 | 만료·종료된 방에 학생 참가            | 거부                   |
| T12 | 오프라인 사건을 같은 eventId로 재전송   | 중복 생성 없음             |
| T13 | 학생 표시코드 변경 후 이전 기록 조회      | 기존 studentId 기록 유지   |
| T14 | 기기 시간을 변경하고 사건 저장          | createdAt은 서버시간      |
| T15 | 새로고침 후 진행 복구               | 완료·시도·힌트·시간 유지       |
| T16 | 클래스인 내장 브라우저에서 입장·저장       | 로그인·마이크·App Check 정상 |

### 운영 전 최종 승인

T01~T16 자동·수동 시험과 개인정보 확인이 모두 통과해야 운영 Firebase와 실제 학생 자료를 연결합니다.



## 10. 개발 완료 정의와 인수인계

아래 항목이 모두 충족되어야 '서버와 데이터베이스 적용 완료'로 판단합니다.

| 완료 확인                    | 기준                                            |
|--------------------------|-----------------------------------------------|
| <input type="checkbox"/> | 자율활동 회원은 구매·구독 권한이 있는 자료만 열 수 있다.             |
| <input type="checkbox"/> | 자율활동에서는 강사 연동 기능과 API가 모두 차단된다.               |
| <input type="checkbox"/> | 승인된 강사만 로그인 후 5자리 수업방을 만들 수 있다.               |
| <input type="checkbox"/> | 학생은 이름과 활성 방 코드로만 해당 수업 세션에 참여한다.             |
| <input type="checkbox"/> | 고정 강사 코드와 고정 학생 코드는 운영 코드에서 제거되었다.            |
| <input type="checkbox"/> | 내부 studentId는 이름·표시코드 변경과 무관하게 유지된다.          |
| <input type="checkbox"/> | activityEvents는 추가 전용이며 학생이 수정·삭제할 수 없다.      |
| <input type="checkbox"/> | 모든 공식 시간은 Firestore 서버시간이다.                   |
| <input type="checkbox"/> | 학부모·강사·관리자의 조회 범위가 Security Rules와 서버에서 제한된다. |
| <input type="checkbox"/> | 오프라인 저장과 중복 방지, 새로고침 복구가 동작한다.                |
| <input type="checkbox"/> | 비밀키와 실제 개인정보가 GitHub·HTML·브라우저 번들에 없다.        |
| <input type="checkbox"/> | Emulator 권한 테스트와 클래스인 브라우저 통합 테스트가 통과했다.      |

### 온큐베이트 측에서 개발자에게 제공할 정보

- Firebase 테스트 프로젝트 접근 권한과 확정된 프로젝트 ID
- 웹·앱 로그인 방식과 결제 시스템 종류
- 구매 상품과 lessonId의 대응표
- 강사 승인·정지·만료 운영 정책
- 학생 기록 보존기간과 삭제 요청 처리 정책
- 운영 도메인과 클래스인에서 사용할 입장 URL

#### 현재 상태 요약

자료와 입장 화면은 준비됐습니다. 서버·데이터베이스·로그인·이용권·실시간 방·보안 규칙은 이 문서를 기준으로 홈페이지 개발자가 구현하고 테스트해야 합니다.

참고 문서: Firebase Authentication, Cloud Firestore, Security Rules, Emulator Suite, App Check 공식 문서